



## ETHICAL HACKING INTERNSHIP

### WEEK 4 — TASK 10

#### Vulnerability Scanning Basics

*Nmap NSE vulnerability scanning, CVE identification and findings analysis*

|                        |                   |
|------------------------|-------------------|
| <b>Submitted By</b>    | Mah Noor          |
| <b>Program</b>         | Cyber Security    |
| <b>Student ID</b>      | TBS-2026-242      |
| <b>Submission Date</b> | 10 September 2026 |

## 1. Objective

- Perform an automated vulnerability scan using Nmap NSE vulnerability scripts.
- Identify potential vulnerabilities from the scan output.
- Map the findings to CVE identifiers and explain the security impact.
- Record practical evidence and document the findings clearly.

## 2. Tool Used

Primary tool: Nmap on Kali Linux.

Target used: 192.168.139.129

## 3. Practical Commands

Service/version detection: `nmap -sV 192.168.139.129`

NSE vulnerability scan: `sudo nmap --script vuln 192.168.139.129`

Evidence note: the supplied screenshots show -sS and -sV scans. The CVE findings below are documented in the Task 10 report; the supplied screenshots do not display the --script vuln output itself.

## 4. Scan Evidence

Figure 1: Nmap SYN scan showing the target host and exposed TCP services.

```

(mahnoor@kali)-[~/Desktop]
$ sudo nmap -sS 192.168.139.129
[sudo] password for mahnoor:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 16:14 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0020s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc

```

Figure 1 — Nmap -sS scan of 192.168.139.129

Figure 2: Nmap service/version detection identifying software versions.

```

(mahnoor@kali)-[~/Desktop]
$ nmap -sV 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 17:04 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0012s latency).
Not shown: 984 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1

```

Figure 2 — Nmap -sV scan of 192.168.139.129

## 5. Services Identified

| Port     | Service      | Detected version / information      |
|----------|--------------|-------------------------------------|
| 21/tcp   | ftp          | ProFTPD 1.3.1                       |
| 22/tcp   | ssh          | OpenSSH 4.7p1 Debian 8ubuntu1       |
| 23/tcp   | telnet       | Version not shown                   |
| 25/tcp   | smtp         | Postfix smtpd                       |
| 53/tcp   | domain       | ISC BIND 9.4.2                      |
| 80/tcp   | http         | Apache httpd 2.2.8 (Ubuntu) DAV/2   |
| 111/tcp  | rpcbind      | 2 (RPC #100000)                     |
| 139/tcp  | netbios-ssn  | Samba smbd 3.x - 4.x                |
| 445/tcp  | microsoft-ds | Samba smbd 3.x - 4.x                |
| 2049/tcp | nfs          | 2-4 (RPC #100003)                   |
| 3306/tcp | mysql        | MySQL 5.0.51a-3ubuntu5              |
| 5432/tcp | postgresql   | PostgreSQL DB 8.3.0 - 8.3.7         |
| 5900/tcp | vnc          | VNC (protocol 3.3)                  |
| 6000/tcp | X11          | access denied                       |
| 6667/tcp | irc          | UnrealIRCd                          |
| 8009/tcp | ajp13        | Apache Jserv (Protocol v1.3)        |
| 8180/tcp | http         | Apache Tomcat/Coyote JSP engine 1.1 |

## 6. Vulnerabilities Identified

| # | Finding               | CVE           | Severity             | Explanation                                                                                                                                                                                                                                             |
|---|-----------------------|---------------|----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 | vsFTPD 2.3.4 backdoor | CVE-2011-2523 | Critical / Very High | A malicious backdoored build of vsFTPD 2.3.4 can open a backdoor when triggered, potentially allowing remote command execution with high privileges. The Task 10 report states that Nmap reported VULNERABLE and a shell command result of uid=0(root). |
| 2 | SSLv3 / POODLE        | CVE-2014-3566 | Medium-High          | SSL 3.0 is vulnerable to the POODLE attack. Under suitable conditions, an attacker in a man-in-the-middle position may recover protected information. The Task 10 report states that the ssl-                                                           |

|  |  |  |  |                                             |
|--|--|--|--|---------------------------------------------|
|  |  |  |  | poodle script reported SSLv3 as vulnerable. |
|--|--|--|--|---------------------------------------------|

## 7. Finding Analysis

The target exposes multiple network services. The most serious documented finding is the vsFTPD 2.3.4 backdoor because the reported scan evidence included a root-level shell result. The SSLv3/POODLE finding is also important because SSLv3 is obsolete and should be disabled in favor of supported TLS versions.

## 8. TryHackMe Proof

Figure 3 — TryHackMe Vulnerabilities 101 completion proof (7 tasks, 72 points)

Figure 3: TryHackMe — Vulnerabilities 101 completion proof (7 tasks, 72 points).

### CVE-2011-2523 Reference Evidence

#### CVE-2011-2523 Detail

##### MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

#### Description

vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.

### Metrics

*NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.*

**CVSS 3.x Severity and Vector Strings:**


**NIST: NVD**

**Base Score:**

9.8 CRITICAL

**Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

#### References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inferences should be drawn on account of other sites being referenced, or not, from this page. There may be other web sites that are more appropriate for your purpose. NIST does not

Figure 3 — NVD reference for CVE-2011-2523 (vsFTPD 2.3.4 backdoor)

### CVE-2014-3566 Reference Evidence

## 🌸 CVE-2014-3566 Detail

### MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

## Description

The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other products, uses nondeterministic CBC padding, which makes it easier for man-in-the-middle attackers to obtain cleartext data via a padding-oracle attack, aka the "POODLE" issue.

### Metrics

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

**CVSS 3.x Severity and Vector Strings:**


**NIST: NVD**

**Base Score:** 3.4 LOW

**Vector:** CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:L/I:N/A:N

CVSS Version 4.0

**CVSS Version 3.x**

CVSS Version 2.0

SSVC

Figure 4 — NVD reference for CVE-2014-3566 (SSL 3.0 / POODLE)

## NSE Vulnerability Scan Evidence

Figure 4 — Nmap NSE vulnerability scan of 192.168.139.129

```
(mahnoor@kali) - [~/Desktop]
$ sudo nmap --script vuln 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 16:19 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0015s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs: CVE:CVE-2011-2523  BID:48539
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         https://www.securityfocus.com/bid/48539
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| ssl-poodle:
|   VULNERABLE:
|     SSL POODLE information leak
|       State: VULNERABLE
|       IDs: CVE:CVE-2014-3566  BID:70574
|       The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|       products, uses nondeterministic CBC padding, which makes it easier
|       for man-in-the-middle attackers to obtain cleartext data via a
|       padding-oracle attack, aka the "POODLE" issue.
|       Disclosure date: 2014-10-14
|       Check results:
|         TLS_RSA_WITH_AES_128_CBC_SHA
|       References:
```

## 9. Mitigation / Recommendations

- Remove the backdoored vsFTPD 2.3.4 installation and replace it with a trusted, patched FTP/SFTP solution.
- Disable SSLv3 and allow only supported TLS versions with secure cipher suites.
- Close unnecessary network ports and restrict access using firewall rules.
- Disable or restrict insecure services such as Telnet where they are not required.
- Repeat the vulnerability scan after remediation to verify that the findings are no longer present.

## 10. Conclusion

Nmap scanning was used to identify exposed services and support vulnerability assessment of the target host. The Task 10 report documents CVE-2011-2523 and CVE-2014-3566 as the principal findings, followed by impact analysis and remediation recommendations. The results demonstrate why vulnerability scanning should be followed by manual validation, risk assessment and remediation.

**End of Task 10 Report**